# Контрольные вопросы

## Лабораторная 1. Восстановление паролей

### 1. Как хранятся пароли в Windows XP? Что такое LM, NT-хеш и SYSKEY?

Для локальных учётных записей Windows XP использует базу SAM. Сам пароль открытым текстом в ней не хранится. Система хранит защищённое представление хеша - результата специальной функции от пароля.

При проверке пароля система считает хеш введённого значения и сравнивает его с сохранённым. Восстановление перебором работает похоже: программа подставляет варианты и ищет совпадение. Хеш не расшифровывают обратно, как обычный зашифрованный текст.

NT-хеш - это MD4 от пароля в UTF-16LE, результат занимает 128 бит. Он учитывает регистр, но не использует индивидуальную соль. Поэтому у одинаковых паролей одинаковые NT-хеши. В интерфейсе Cain этот тип обозначен NTLM; сам NTLM также является названием семейства протоколов аутентификации.

LM - более старая и слабая схема. Пароль переводится в верхний регистр, дополняется до 14 байт и разбивается на две части по 7 байт. Из каждой части получается DES-ключ для обработки фиксированной строки; два результата соединяются. Регистр теряется, а половины можно подбирать отдельно - это сильно облегчает восстановление.

SYSKEY в старых Windows дополнительно защищал сохранённые хеши системным ключом. Он затруднял их извлечение из базы, но не делал слабый пароль сильным и не добавлял соль к NT-хешу.

### 2. Какие есть четыре основных режима восстановления? Их плюсы и минусы?

| Режим | Как работает и в чём плюс | Ограничение |
|---|---|---|
| По словарю | Проверяет готовый список вероятных слов и паролей. Часто быстро находит популярные варианты. | Случайного пароля может не оказаться в словаре. |
| Полный перебор | Перебирает все варианты заданной длины и алфавита. Покрывает всё выбранное пространство. | С ростом длины время увеличивается очень быстро. |
| Гибридный | Меняет слова из словаря: добавляет цифры, заменяет буквы. Подходит для вариантов вроде slovo123. | Успех зависит от словаря и выбранных правил. |
| По маске | Учитывает известную структуру: например, шесть цифр. Убирает лишние варианты. | Ошибка в маске может полностью исключить нужный пароль. |

В методичке ещё есть радужные таблицы: часть вычислений сделана заранее и сохранена в таблицах. Это требует места и подходит только к определённому алгоритму и диапазону паролей. Соль мешает использовать одну готовую таблицу для всех пользователей.

**3. Что такое условно простой или сложный пароль? Что требует Microsoft в методичке?**

Простой пароль в смысле этой лабы - такой, который удаётся восстановить быстро на выбранном компьютере. В методичке указан ориентир от 15 секунд до 15 минут. Сложный требует заметно больше времени. Это относительная оценка: она зависит от оборудования, алгоритма и того, что известно о пароле.

Исторические рекомендации Microsoft в методичке: не менее 7 символов, несколько групп символов, отсутствие личных данных и популярных комбинаций вроде qwerty или 12345. Среди групп перечислены буквы разного регистра, цифры и специальные знаки.

Для объяснения на защите: длина и непредсказуемость важнее формальной галочки «есть большая буква и цифра». Например, Password1! выглядит разнообразно, но его легко получить словарными правилами. Указанные 7 символов - требование из старой методички, а не универсальная современная гарантия стойкости.

**4. Что такое подсоленный пароль?**

Обычно под этим понимают хеширование пароля с солью. Соль - отдельное случайное значение для каждой записи. Условно: результат = функция(пароль, соль). Соль сохраняется рядом с результатом, скрывать её необязательно.

Например, два человека выбрали одинаковый пароль. Без соли их хеши одинаковы. С разными солями результаты различаются, поэтому готовые таблицы нельзя просто применить ко всем сразу: для каждой соли придётся считать заново.

Соль сама по себе не делает короткий пароль длинным и не мешает проверять варианты для одной конкретной записи. Поэтому используют ещё и затратную функцию получения ключа или хеша: Argon2id, scrypt либо PBKDF2. В обычном NT-хеше Windows индивидуальной соли нет.

**Как связать ответы со своим опытом**

В первой работе использовался полный перебор NTLM-хеша с цифровой маской. Измеренная скорость - 21 021 990 проверок/с. Найден пароль длиной 10 цифр, время по секундомеру - 7 минут 56 секунд.

Формула: N = A^L, T полного прохода = N/V. При добавлении одной цифры вариантов становится в 10 раз больше. Среднее время для случайного равновероятного пароля - примерно половина полного прохода.

# Контрольные вопросы

## Лабораторная 2. Симметричное шифрование

### 1. Что такое симметричная криптография?

Это шифрование, в котором для шифрования и расшифрования используется один и тот же секретный ключ. Кто знает ключ, тот может восстановить исходные данные. Пример - AES, который использован в программе.

Пароль и ключ не обязательно совпадают. В нашей программе пароль вводит человек, а PBKDF2 получает из него ключ нужного размера. Для AES-192 это 192 бита, то есть 24 байта.

PBKDF2 многократно выполняет вычисления с паролем и солью. Получить ключ с известным паролем можно быстро, но массовая проверка миллионов вариантов становится дороже. Случайная соль даёт разные ключи даже при одинаковых паролях.

### 2. Какие у неё достоинства и недостатки?

Плюсы: высокая скорость и небольшие затраты ресурсов. Поэтому симметричные алгоритмы удобны для файлов, дисков и больших объёмов сетевого трафика.

Главная сложность - безопасно передать ключ другому человеку и сохранить его в секрете. Если ключ украден, данные можно расшифровать. Если разные пары участников используют отдельные ключи, управлять ими становится сложнее.

Само шифрование скрывает содержимое, но не всегда обнаруживает подмену. Например, к AES-CBC в нашей работе добавлен HMAC. Есть и режимы, которые сразу дают шифрование с проверкой целостности, например GCM.

### 3. Кратко охарактеризуйте DES, 3DES, ГОСТ-89 и AES.

| Алгоритм | Размеры и устройство | Что запомнить |
|---|---|---|
| DES | Ключ 56 бит, блок 64 бита. Сеть Фейстеля, 16 раундов. | Ключ слишком короткий для современной защиты: возможен полный перебор. |
| 3DES | Три операции DES, обычно E-D-E. Для трёх независимых ключей номинально 168 бит, блок 64 бита. | Известные атаки дают около 112 бит общей стойкости. Медленный, унаследовал небольшой блок DES. |
| ГОСТ 28147-89 | Ключ 256 бит, блок 64 бита. Сеть Фейстеля, 32 раунда. | Использует подстановки, сложение по модулю 2^32 и циклический сдвиг. Важны параметры таблиц подстановок. |
| AES | Блок всегда 128 бит. Ключ 128, 192 или 256 бит; соответственно 10, 12 или 14 раундов. | Сеть подстановок и перестановок. В нашем варианте AES-192: 24 байта ключа и 12 раундов. |

Главная разница размеров: у AES-192 число 192 относится к ключу. Блок при этом всё равно 128 бит, или 16 байт. AES не является сетью Фейстеля.

**4. В чём заключаются принципы Керхгоффса?**

Главный для современной криптографии: стойкость системы должна опираться на секретность ключа, а не на тайну алгоритма. Можно знать устройство AES и исходный код программы, но без правильного ключа данные должны оставаться защищёнными.

В исторической формулировке Керхгоффс перечислил шесть требований: система должна быть практически нераскрываемой; сохранять защиту при раскрытии её устройства; позволять легко передавать, запоминать и менять ключ; подходить для телеграфной связи; быть переносимой и обслуживаться одним человеком; оставаться простой в применении.

Для ответа своими словами: «Алгоритм может быть открытым. Секретом должен оставаться ключ, а пользоваться системой должно быть удобно».

**5. О чём работа Шеннона «Теория связи в секретных системах»?**

Работа Клода Шеннона 1949 года дала математическую основу анализа шифров. Он связал секретность с количеством информации: насколько наблюдение шифротекста помогает узнать исходное сообщение.

Совершенная секретность означает, что шифротекст не даёт дополнительной информации об открытом тексте. Пример - правильно применённый одноразовый блокнот: полностью случайный независимый ключ не короче сообщения, который используется только один раз. Обычный AES с коротким относительно файла ключом не даёт такой теоретической гарантии; его стойкость основана на вычислительной сложности атак.

Ещё две важные идеи - перемешивание и рассеивание. Перемешивание усложняет связь между ключом и шифротекстом. Рассеивание распределяет влияние элементов исходного текста по результату, чтобы его статистические особенности не были видны напрямую. В современных блочных шифрах эти эффекты усиливаются повторением раундов.

**6. Что такое сеть Фейстеля и как она связана с идеями Шеннона?**

Блок делится на левую и правую половины L и R. Один раунд устроен так: новая левая половина равна старой правой; новая правая получается из старой левой через XOR с функцией от правой половины и раундового ключа.

```
L_next = R
R_next = L XOR F(R, K)
```

У XOR есть удобное свойство: (A XOR B) XOR B = A. То есть повторение той же операции с B возвращает исходное A. На этом и основана обратимость раунда.

Дальше такие раунды повторяются. При расшифровании раундовые ключи используются в обратном порядке. Функция F сама не обязана быть обратимой: конструкция позволяет восстановить обе половины благодаря свойствам XOR.

Сеть Фейстеля появилась позже работ Шеннона и реализует его идеи перемешивания и рассеивания с помощью многократных раундов. Сам Шеннон эту сеть не изобретал. Примеры такой конструкции - DES и ГОСТ 28147-89.

Источник вопросов: методические указания к лабораторной 1, с. 7, и к лабораторной 2, с. 11. Вопросы 4-6 второй лабы в методичке обозначены как дополнительные.